Independent supervisor source review

Verdict: changes required before execution. All 19 producer/source binding hashes match. This review inspected source and frozen plans only; it launched no Docker client, container, cloud command, or reviewed executable. Reviewer previously prepared runtime-route inspection/compiler-prerequisite evidence, not this supervisor.

R1 — Manifest identity is not member identity (supervise.py 37,98–103,145,174). The fixed fixture manifest itself is hashed, but no manifest member hashes are verified. The pre/post snapshot allows preexisting changes; preparation.json and expected-report.json are read without comparison to their frozen hashes. A coherent changed fixture/expected report could pass the software comparisons. Required correction: Verify all consumed manifest members and exact fixture membership against the bound manifest before Docker; retain before/after identity checks.

R2 — Interrupted Docker client remains owned but unreaped (supervise.py 55–75,148–149,180–183). The signal handler raises Stop while command is running. Generic exceptions enter finally, which writes only a receipt. Only timeout/output-cap code terminates the process group. Container cleanup may race a still-running create/start client; the direct child can remain unreaped. Required correction: On every exceptional exit, terminate and reap the owned client before container reconciliation; preserve interruption and incomplete-client-cleanup receipts. Do not equate client termination with container death.

R3 — Runtime expected files can pass as directories (supervise.py 119–122,163–171). Actual archive kind is never compared with runtime-members kind. For an expected executable file with mode0755, an actual directory with mode0755 passes the mode test and bypasses its SHA via x.directory or hash==expected. Q1/Q3 do not execute the recovery/progress runtime files. Required correction: Require exact expected file/directory kind, expected file length, and SHA for every ordinary file before acceptance.

R4 — Inspect redaction is not exception-safe (supervise.py 57,67–75). Full inspect stdout is first written to stdout.raw. Timeout, output cap or JSON parsing failure leaves that raw file; redaction/unlink occurs only on the successful normal path. This contradicts unconditional redacted inspection-receipt scope. Required correction: Use private transient capture with guaranteed cleanup/sanitization on every path; retain digest/error metadata without raw environment values.

R5 — Isolation assertions cover only part of actual configuration (supervise.py 109–114). Mount checking filters only bind mounts, so anonymous/image-declared volumes are not rejected. Tmpfs checks names only, not options. IPC mode, CapAdd and DeviceRequests are unasserted. Command arguments request restrictive values but inspection does not prove the full declared contract. Required correction: Compare an exact approved mount inventory and tmpfs values; reject extra volumes/devices/capabilities and validate IPC/seccomp/configuration as applicable. Preserve requested-versus-effective distinction.

R6 — Executable archive ownership claim exceeds checks (supervise.py 159–161). Executable archives verify bytes and0755 but omit uid/gid checks. The /opt ownership loop does not cover /usr/local/bin/ecbench or isolab-fresh-owner. Required correction: Check root uid/gid for both executable archives, or narrow the stated ownership claim. Scope /opt ancestor checks explicitly to /opt rather than all executable ancestors.

The prestart PID gap is accurately disclosed. Daemon PidsLimit support and HostConfig.PidsLimit=1 establish configuration/support; an opportunistic after-start cgroup read cannot establish effective enforcement before start. qualification_complete and effective_before_start_proved stay false, with exit3 on otherwise successful checks. This is appropriate partial-status reporting, not closure of the retained qualification gate.

Q0 broadens the retained explicit-member read to a bounded full /opt tar with an exact allowlist. This is a prospective scope addition, not an already executed allowance. It rejects unexpected members and never extracts archive paths. A base-image /opt extra or oversized tree can make this fail closed; no compatibility was observed. It covers /opt ancestry, not /usr/local/bin ancestry.

Positive source observations: immutable image ID and Docker client digest, env-i explicit local socket route, pull=never, unique container label/name/ID/image matching, one-container ownership, exact-ID removal and retained cleanup-incomplete status. Root supplies independently reviewed final-build joins; the supervisor only checks hash shapes and embedded build-info equality and is not a build-receipt verifier. Scientific admission remains false. Owner exit125 matches the retained early digest-rejection contract.

Timeouts are orchestration limits, not guaranteed daemon termination. The shared300second deadline,30second cleanup reserve and20second active deadline are explicit. Filesystem stalls, signal interruption and daemon behavior still need the corrected cleanup design and future bounded validation. A further receipt hardening item: outer fallback at lines193–196 labels docker_actions_started=false unconditionally; after a final receipt-write failure this should instead use tracked action state or unknown.

Producer is preparing an additive revision after receiving findings R1–R6. This review preserves v1 and does not approve unseen changes. No test execution or repair occurred. The new version needs fresh source review and separate prospective admission.